

CyberLab Assistant (CLA) 学生端使用手册

浏览器终端实践、分级提示、答案提交、成绩证据与申诉

适用对象：网安实践课程学生

生成日期：2026-06-25

项目名称：CyberLab Assistant (CLA)

相关规格：cla_terminal_first_complete_development_spec.html

目录

1. 文档定位与学习路径
2. 登录、token 与页面入口
3. 学生工作台布局
4. 启动 Attempt 与 LabSession
5. 使用浏览器终端
6. 重连与重置
7. 任务完成方式与提交前检查
8. 使用 L1、L2、L3 分级提示
9. 理解辅助状态
10. 提交答案
11. 成绩摘要与完整证据页
12. 提交申诉
13. 隐私、诚信与安全使用
14. 常见问题与排障
15. 本地和 IPv6 访问说明
16. 学生端操作清单
17. 学生端功能速查

1. 文档定位与学习路径

本文是 CyberLab Assistant (CLA) 学生端使用手册，面向参加网安实践课程的学生。它从登录、启动实验、使用浏览器终端、请求提示、提交答案、查看成绩到提交申诉，按完整学习流程说明每一步。

你将使用什么：当前学生端是终端优先的一期实现。你会在浏览器中看到 xterm.js 终端，连接到属于自己 Attempt 的隔离 LabSession。平台不会把容器地址、内部路由或 sessionid 地址暴露给浏览器。

- 1. 登录或写入开发 token。
- 2. 打开学生工作台。
- 3. 点击 启动 创建 Attempt 和终端会话。
- 4. 在浏览器终端中完成实践任务。
- 5. 必要时请求 L1、L2、L3 分级提示。
- 6. 在右侧提交区填写根因解释并提交。
- 7. 查看成绩证据页，理解每个评分项。
- 8. 如有充分理由，选择具体评分项提交申诉。

2. 登录、token 与页面入口

生产环境通常通过学校或平台统一登录。当前本地开发实例使用 claDevToken 模拟学生身份。教师或管理员会提供学生 token。

- 1. 打开 http://127.0.0.1:3000。
- 2. 如果是开发模式，打开浏览器控制台。
- 3. 执行 localStorage.setItem("claDevToken", "<student-token>")。
- 4. 刷新页面。
- 5. 页面顶部当前 Attempt 显示 未创建 时，说明还没有开始本次作业。

```
// 写入学生 token
localStorage.setItem("claDevToken", "<student-token>")

// 查看当前 token
localStorage.getItem("claDevToken")

// 清理 token
localStorage.removeItem("claDevToken")
```

入口	路径	用途
学生工作台	/	启动实验、连接终端、请求提示、提交答案、查看简要成绩
完整成绩证据页	/student/grades/{attemptId}	查看总分、独立完成指数、每项证据和申诉入口

身份安全：不要把自己的 token 发给同学，也不要把 token 写进提交答案、终端命令或截图。开发 token 只用于本地环境，正式课程以管理员说明为准。

3. 学生工作台布局

学生工作台分为左侧导航、中间终端区域和右侧辅助/提交/成绩区域。页面使用中文按钮，少数状态字段保留英文状态码，便于和系统日志、教师监控一致。

区域	你会看到	用途
左侧导航	Terminal、Evidence、Appeal	当前主要使用 Terminal ; Evidence 和 Appeal 对应成绩和申诉流程
顶部状态栏	当前 Attempt、连接状态、session/epoch	确认自己是否已创建 Attempt、终端是否连接
中间终端	黑色终端窗口	输入命令、运行工具、观察输出
底部操作	启动、重连、重置	创建或恢复会话，必要时重置实验环境
右侧辅助	状态、L1/L2/L3 按钮、最近提示、反馈按钮	请求或管理教学提示
右侧提交	答案文本框、提交 按钮	提交根因解释和开放答案
右侧成绩证据	Total、各 criterion 简要分数、完整证据页链接	提交后快速查看成绩摘要

焦点行为：提示和平台状态不会抢占终端焦点。终端连接成功后，光标通常在终端内，可以直接输入命令。

4. 启动 Attempt 与 LabSession

Attempt 表示你对某个作业的一次实践记录。LabSession 表示本次 Attempt 对应的隔离实验环境。点击 启动后，系统会创建 Attempt、创建或确保 LabSession、签发一次性终端票据，并连接 Gateway。

1. 确认页面已经登录，右上或顶部没有认证错误。
2. 点击 启动。
3. 状态从 idle 变成 provisioning，表示正在准备环境。
4. 环境就绪后，状态变成 connected。
5. 顶部会显示 Attempt ID，以及 session ID 和 epoch。
6. 终端出现 shell 提示符后即可输入命令。

状态	含义	你应该做什么
idle	未开始或当前没有连接	点击 启动
provisioning	正在创建 Attempt、会话或票据	等待，不要反复点击
connected	终端已连接	开始实践
closed	WebSocket 关闭	点击 重连
error	连接或 API 出错	查看页面错误信息，必要时刷新或联系教师

一次性票据：终端票据是 60 秒内有效的一次性票据，绑定 user、attempt、session epoch、audience、nonce 和过期时间。你不需要也不应该手动复制或保存它。

5. 使用浏览器终端

终端是你完成实践的主要工具。它通过二进制 WebSocket 与 Gateway 通信，支持 UTF-8、resize、heartbeat、ACK 和短时间重连 replay。

- 输入命令后按 Enter 执行。
- 调整浏览器窗口大小时，页面会向服务端发送 resize。
- 终端输出很多时，浏览器会进行流控；不要把超大二进制内容直接打印到终端。
- 如果网络短暂断开，重连时会携带最后收到的 server sequence，Gateway 尝试回放缓冲输出。
- 不要在终端里输出自己的 token、个人密码、浏览器 localStorage 或其他敏感信息。

```
# 示例：确认 shell 可用
pwd
whoami
ls
```

```
# 示例：访问题目目标，具体目标地址以题目说明为准
curl -i http://target:8080/
```

终端证据边界：终端文本会被视为不可信数据。它可以辅助教学和证据引用，但正式客观通过依赖学生控制边界外的 Oracle 或平台签名事件。

6. 重连与重置

重连 和 重置 是两个不同动作。重连保留当前 LabSession 和 session epoch，只重新获取票据并连接终端。重置会创建新的 session epoch，旧票据和旧路由失效。

按钮	会发生什么	适用场景	风险
重连	复用当前 Attempt 和 LabSession，重新签发终端票据	网络断开、页面刷新、状态为 closed	通常不会清空实验状态
重置	重置当前 Attempt 的实验会话，session epoch 递增	环境损坏、命令误操作导致无法继续	可能清空当前环境状态，且可能受次数限制

1. 看到 closed 时，先点击 重连。
2. 看到 error 且错误与票据过期、nonce 重放或网络断开有关，也先尝试 重连。
3. 只有当环境状态被破坏、目标无法恢复或教师建议时，再点击 重置。
4. 重置后等待状态回到 connected，不要继续使用旧页面里保存的任何票据信息。

7. 任务完成方式与提交前检查

不同题目有不同目标。以默认 Web SQL

登录题为例，你需要通过终端工具分析目标行为，完成要求的状态改变或验证目标，然后提交根因解释。不要把最终 payload 当成唯一答案，成绩通常同时看客观 Oracle 与解释质量。

- 已阅读题目目标和允许工具。

- 已确认当前终端属于自己的 Attempt。
- 已完成题目要求的客观动作，例如触发目标状态、访问验证端点或完成指定操作。
- 已记录关键观察，例如输入与输出的差异、错误信息、服务行为变化。
- 已理解根因，而不是只复制某条命令。
- 没有在答案中写入 token、动态 secret、他人信息或平台内部地址。
- 如使用了提示，已理解提示内容，并能用自己的话解释。

答案内容边界：如果题目明确要求不要泄露最终 payload 或动态 secret，答案中也不应该出现这些内容。可以描述漏洞类型、验证思路、影响和修复建议。

8. 使用 L1、L2、L3 分级提示

右侧辅助面板提供 L1、L2、L3 三个等级。它们用于在你卡住时提供不同粒度的帮助。系统也可能根据卡住检测状态主动生成提示，但你可以反馈或关闭自动提示。

等级	典型内容	何时使用
L1	方向性提醒，例如检查目标、阅读错误、回顾概念	刚开始不确定下一步时
L2	更具体的排查路径，例如建议尝试某类请求或观察某类响应	尝试多次仍无法定位时
L3	接近操作层面的强提示，但不应泄露最终 payload 或动态 secret	临近截止或长期卡住时

1. 点击 L1、L2 或 L3。
2. 查看提示卡片中的等级、状态、tutor version 和内容。
3. 查看 evidence refs，理解系统为什么给出这个提示。
4. 如果提示有帮助，点击 接受。
5. 如果暂时不需要，点击 稍后。
6. 如果你认为系统误判卡住，点击 这不是卡住。
7. 如果不想再收到自动提示，点击 关闭自动提示。

提示与成绩：提示使用只影响独立完成指数，不直接改变总分。独立完成指数用于呈现学习过程依赖程度，不是单独扣分按钮。

9. 理解辅助状态

辅助面板会显示当前卡住评估状态和分数。这个分数表示卡住可能性，不是作业成绩，也不是作弊判断。

状态	含义	建议
NORMAL	系统未发现明显卡住迹象	继续实践
SUSPECTED	系统发现一些卡住特征	可以先请求 L1 或重新检查题目目标

状态	含义	建议
CONFIRMED	系统认为卡住可能较高	请求更高等级提示，或向教师说明你已经尝试过什么
自动提示开启	系统可能主动展示提示	可按需反馈
自动提示已关闭	系统不再主动提示	仍可手动点击 L1/L2/L3

- 重复同一条失败命令可能提高卡住评分。
- 长时间运行的正常任务会被排除，系统不应仅因等待而判定卡住。
- 探索新的命令、观察新响应和达成里程碑通常会降低卡住风险。
- 如果系统提示不符合你的实际情况，使用反馈按钮比忽略更有价值。

10. 提交答案

完成实践后，在右侧 **提交** 区域填写答案。当前默认提交一个 root-cause 问题，格式为 Markdown。提交后系统会请求 Oracle 检查并生成 GradeRevision。

1. 在答案文本框中写清楚漏洞或问题的根因。
2. 说明你如何验证该根因，例如关键请求、响应差异或目标状态变化。
3. 说明影响和修复建议，如果题目要求。
4. 确认答案中没有 token、动态 secret 或平台内部地址。
5. 点击 **提交**。
6. 等待成绩摘要出现。如果暂时显示 no grade，可稍后刷新或进入完整证据页。

好答案通常包含	不建议包含
漏洞类型和触发条件	无关的终端大段输出
关键观察和验证方法	未脱敏的 token、Cookie、Authorization
为什么这个操作证明问题存在	同学的答案或他人信息
修复思路或防护建议	动态 flag 或题目明确禁止公开的 payload

11. 成绩摘要与完整证据页

提交后，工作台右侧会显示 Total 和每个 criterion 的简要分数。点击 **完整证据页** 进入更详细页面。完整证据页是你理解成绩和申诉的主要依据。

1. 在工作台右侧找到 **成绩证据**。
2. 查看 Total 总分。
3. 查看每个 criterion 的简要得分。
4. 点击 **完整证据页**。
5. 在新页面查看总分、独立完成指数、Attempt、Revision、Rubric、Grader 和 Published。
6. 逐项点击 criterion，阅读得分、评分类型、置信度、解释和 evidence refs。

字段	含义	你应该关注什么
总分	本次最新 GradeRevision 的总分	是否符合预期
独立完成指数	提示依赖程度指标	理解自己的求助情况
Revision	成绩修订号和状态	申诉后可能递增
Rubric	评分标准版本	不同版本不可混淆
Grader	评分器版本	用于复现和排错
criterionId	评分项 ID	申诉时必须选择具体项
score/maxScore	单项得分	定位失分点
graderType	评分方式	Oracle、事件模式或开放评价
confidence	置信度	低置信可请求教师复核
evidenceRefs	证据引用	判断评分是否有依据

12. 提交申诉

如果你认为某个评分项有误，可以在完整证据页右侧提交申诉。申诉必须针对具体 criterion，不能只写“分数不对”。

1. 打开完整成绩证据页。
2. 在右侧 申诉 面板中选择要申诉的标准。
3. 阅读该标准当前分数、评分类型和 evidence refs。
4. 在理由框中写明具体原因，至少 3 个字符。
5. 说明你认为哪个证据遗漏、哪条解释不准确、或哪个评分项应如何调整。
6. 点击 提交申诉。
7. 看到 OPEN 状态和 Appeal ID 后，等待教师复核。

有效申诉	无效或低质量申诉
指出具体 criterion 和证据引用	只写“老师我应该满分”
说明实际完成步骤与证据之间的关系	粘贴无关终端输出
解释为什么评分解释与事实不一致	要求系统泄露 Oracle 或标准答案
提供可复核的观察和时间点	包含 token、Cookie 或他人信息

复核结果：教师复核如果覆盖成绩，会生成新的 GradeRevision，旧成绩不会被删除。你之后看到的 Revision 可能递增。

13. 隐私、诚信与安全使用

CLA 的目标是帮助你在隔离环境中学习真实安全实践。平台会收集必要的事件、证据引用和评分信息，但不应公开你的完整终端明文。你也需要遵守课程规则和安全边界。

- 只在平台分配给你的 Attempt 中操作，不尝试访问他人的 Attempt、课程或会话。

- 不要攻击平台控制平面、教师页面、Gateway、sessiond、API 或身份系统。
- 不要尝试复用、篡改或分享终端票据。
- 不要把 token、Cookie、Authorization、动态 flag 或个人密码写进答案。
- 不要把题目最终 payload 在公共渠道传播，除非教师明确允许。
- 不要把系统辅助状态当作成绩本身；它是教学过程信号。
- 发现平台漏洞或越权风险时，立即报告教师或管理员。

Prompt Injection 边界：终端、网页、附件和学生答案中的自然语言都被平台视为不可信数据。它们不能改变系统指令、工具权限或评分规则。

14. 常见问题与排障

问题	可能原因	处理方式
页面显示 API 认证失败	未写入 token 或 token 不是学生角色	重新写入学生 token，刷新页面
点击启动后一直 provisioning	环境启动慢、API 或 sessiond 不可用	等待一会儿，仍失败则联系教师
状态变成 closed	WebSocket 关闭或网络中断	点击 重连
状态变成 error	票据过期、nonce 重放、Gateway 不通或 API 错误	刷新页面后重连，记录错误码给教师
终端没有输出	Gateway 未连接 sessiond、shell 未启动或浏览器连接异常	先重连，再联系教师检查服务
点击提交后没有成绩	评分还没完成、Oracle 未产生证据或网络错误	等待后刷新，必要时联系教师
成绩页显示暂无成绩	Attempt ID 错误或尚未提交	回到工作台确认 Attempt ID 并提交
申诉按钮不可用	未选择 criterion、理由少于 3 个字符或没有成绩	补充理由并选择评分项
提示看起来不相关	系统可能误判卡住场景	点击 这不是卡住 并继续实践
自动提示打扰操作	自动提示开启	点击 关闭自动提示

15. 本地和 IPv6 访问说明

本地开发环境常见访问地址是 `http://127.0.0.1:3000`。如果教师给出 IPv6 地址，你可以直接在浏览器打开。页面会尽量把终端 WebSocket 地址改写为当前页面主机，保证远程访问时不会错误连接到你自己电脑的回环地址。

- 本机访问优先使用 `http://127.0.0.1:3000`。
- 同一局域网或校园网访问 IPv6 地址时，应使用教师给出的完整 `http://[ipv6]:3000/` 格式。
- 如果页面能打开但终端不能连，可能是 Gateway 端口、防火墙或 IPv6 监听问题。
- 如果静态资源加载失败，可能是 Web standalone 静态文件复制不完整，需要教师修复部署。

16. 学生端操作清单

- 确认自己使用的是学生账号或学生 token。
- 打开学生工作台并点击 启动。
- 确认状态为 connected，Attempt ID 和 session epoch 已显示。
- 在终端中完成题目要求，不攻击平台控制平面。
- 卡住时先请求 L1，再根据需要请求 L2 或 L3。
- 对不准确提示及时反馈。
- 提交前检查答案不包含 token、动态 secret 或内部地址。
- 提交后查看成绩摘要和完整证据页。
- 如需申诉，选择具体 criterion 并写清事实依据。
- 课程结束后清理开发 token，尤其是在共享电脑上。

17. 学生端功能速查

你要做什么	入口	说明
开始实验	工作台 启动	创建 Attempt、LabSession 和终端连接
恢复连接	工作台 重连	保留当前环境，重新签发票据
清理环境	工作台 重置	新 session epoch，旧票据失效
输入命令	中间终端	浏览器终端连接隔离 workspace
请求提示	右侧 L1/L2/L3	分级辅助，不泄露最终 payload
反馈提示	提示卡片按钮	接受、稍后、这不是卡住、关闭自动提示
提交答案	右侧提交区	填写 root-cause 解释并提交
查看简要成绩	右侧成绩证据	显示 Total 和各项简要分数
查看完整成绩	完整证据页	查看每项得分、解释和证据引用
提交申诉	成绩页右侧申诉面板	按 criterion 提交具体理由